

Message Authentication Codes and Authenticated Encryption

CS 171: Cryptography

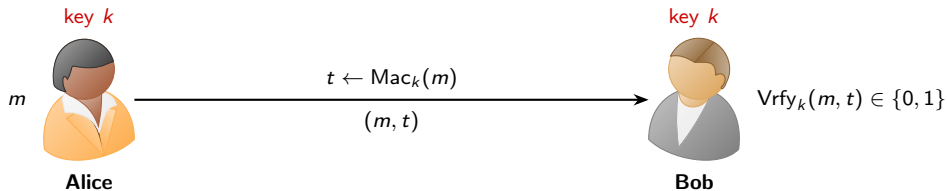
Sanjam Garg

October 1, 2026

Overview

- 1 Recall: MACs
- 2 Authenticated Encryption
- 3 Constructing Authenticated Encryption
- 4 Proof: Encrypt then Authenticate
- 5 Secure Communication Sessions
- 6 Summary

MACs: Recall



Message Authentication Code $\Pi = (\text{Gen}, \text{Mac}, \text{Vrfy})$

- $\text{Gen}(1^n)$ outputs a key k ; $\text{Mac}_k(m)$ outputs a tag t ; $\text{Vrfy}_k(m, t)$ outputs 0 or 1.
- **Correctness:** $\text{Vrfy}_k(m, \text{Mac}_k(m)) = 1$ for all $k \leftarrow \text{Gen}(1^n)$ and all m .
- **Canonical verification** (deterministic Mac): output 1 iff $\text{Mac}_k(m) = t$.

Unforgeability: Recall

Game $\text{MacForge}_{\mathcal{A}, \Pi}(n)$

- 1 $k \leftarrow \text{Gen}(1^n)$. $\mathcal{A}$ is given 1^n and **oracle access** to $\text{Mac}_k(\cdot)$. Let M be the set of messages $\mathcal{A}$ queries.
- 2 $\mathcal{A}^{\text{Mac}_k(\cdot)}$ outputs a pair (m^*, t^*) .
- 3 Output 1 if $\text{Vrfy}_k(m^*, t^*) = 1$ and $m^* \notin M$, and 0 otherwise.

Definition 1 (EU-CMA)

Π is **existentially unforgeable under an adaptive chosen-message attack** (*eu-cma-secure*) if for all PPT $\mathcal{A}$: $\Pr [\text{MacForge}_{\mathcal{A}, \Pi}(n) = 1] \leq \text{negl}(n)$.

Strong unforgeability (suf-cma)

Same game, but M records the pairs (m, t) and $\mathcal{A}$ wins if $(m^*, t^*) \notin M$: a *new tag* on an *already-queried* message also counts.

Saw Last Time

- **Fixed length:** $\text{Mac}_k(m) := F_k(m)$ for a PRF F is eu-cma-secure for $m \in \{0,1\}^n$ (*proved*).
- **Arbitrary length:** tag every block $r \parallel \ell \parallel i \parallel m_i$ with a fresh r per message (*proved*).
 - Inefficient: the tag is about $4\ell n$ bits for an ℓ -block message.
- **Efficient:** CBC-MAC, an n -bit tag for any message length.
 - Secure for messages of one fixed length (*not proved in lecture*); insecure for variable lengths.
 - Arbitrary length: CBC-MAC on $|m| \parallel m$ (Method 1), or $F_{k'}$ of the CBC-MAC under an independent key k' (Method 2).

Secrecy and Integrity

- **Encryption** (CPA- or CCA-secure) gives **secrecy**: the adversary learns nothing about m .
- A **MAC** gives **integrity**: the adversary cannot get a message Alice never sent accepted — but m is sent in the clear.

Goal

One private-key encryption scheme that gives **both at once**. First we need a notion of integrity for *encryption*.

Unforgeable Encryption

Game $\text{EncForge}_{\mathcal{A}, \Pi}(n)$

- 1 $k \leftarrow \text{Gen}(1^n)$. $\mathcal{A}$ is given 1^n and **oracle access** to $\text{Enc}_k(\cdot)$. Let Q be the set of messages $\mathcal{A}$ queries.
- 2 $\mathcal{A}^{\text{Enc}_k(\cdot)}$ outputs a ciphertext c^* .
- 3 Output 1 if $\text{Dec}_k(c^*) \notin \{\perp\} \cup Q$, and 0 otherwise.

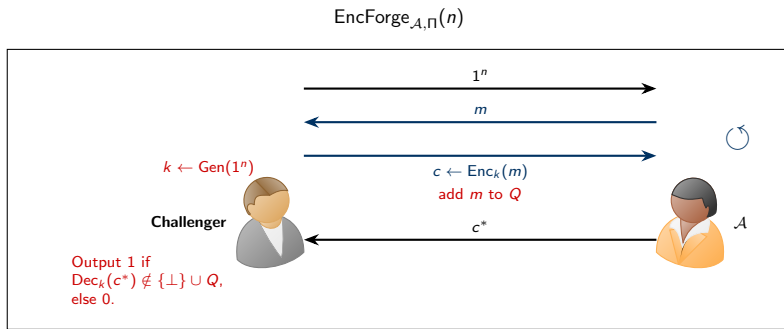
Definition 2 (Unforgeable Encryption)

$\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$ is **unforgeable** if for all PPT $\mathcal{A}$:

$$\Pr [\text{EncForge}_{\mathcal{A}, \Pi}(n) = 1] \leq \text{negl}(n).$$

Dec may now output $\perp$ (“invalid ciphertext”). $\mathcal{A}$ wins if c^* decrypts to a valid message it never asked to have encrypted.

EncForge_{A,Π}: Challenger vs. Adversary



Compare with MacForge

Same shape: oracle queries, then one forgery. The forgery is a ciphertext, and it counts if it decrypts to *any* valid message outside Q .

Is This Scheme Unforgeable?

Construction (recall, lecture 5)

Let $F : \{0, 1\}^n \times \{0, 1\}^n \rightarrow \{0, 1\}^n$ be a PRF.

- $\text{Gen}(1^n)$: sample $k \leftarrow \{0, 1\}^n$.
- $\text{Enc}_k(m)$ for $m \in \{0, 1\}^n$: sample $r \leftarrow \{0, 1\}^n$ and output $c := \langle r, F_k(r) \oplus m \rangle$.
- $\text{Dec}_k(c)$: parse $c = \langle r, s \rangle$ and output $m := F_k(r) \oplus s$.

This scheme is CPA-secure. **Is it unforgeable?**

No!

$\mathcal{A}$ makes **no** queries ($Q = \emptyset$) and outputs any $c^* = \langle r, s \rangle$. Dec_k never outputs $\perp$, so $\text{Dec}_k(c^*) = F_k(r) \oplus s \notin \{\perp\} \cup Q$: $\mathcal{A}$ wins with probability 1.

Authenticated Encryption

Definition 3 (Authenticated Encryption)

A private-key encryption scheme is an **authenticated encryption** scheme if it is **CCA-secure** *and* **unforgeable**.

- **Unforgeable**: integrity, as defined by EncForge.
- **CCA-secure**: secrecy, even against an adversary with a decryption oracle (lecture 6).

CCA-Security: Recall

Game $\text{PrivK}_{\mathcal{A}, \Pi}^{\text{CCA}}(n)$

- ① $k \leftarrow \text{Gen}(1^n)$. $\mathcal{A}$ is given 1^n and **oracle access** to $\text{Enc}_k(\cdot)$ and $\text{Dec}_k(\cdot)$.
- ② $\mathcal{A}^{\text{Enc}_k(\cdot), \text{Dec}_k(\cdot)}$ outputs $m_0, m_1 \in \{0, 1\}^*$ with $|m_0| = |m_1|$.
- ③ $b \leftarrow \{0, 1\}$, $c^* \leftarrow \text{Enc}_k(m_b)$.
- ④ c^* is given to $\mathcal{A}^{\text{Enc}_k(\cdot), \text{Dec}_k(\cdot)}$, which may **not** query $\text{Dec}_k(\cdot)$ on c^* .
- ⑤ $\mathcal{A}^{\text{Enc}_k(\cdot), \text{Dec}_k(\cdot)}$ outputs a guess b' .
- ⑥ Output 1 if $b = b'$, and 0 otherwise.

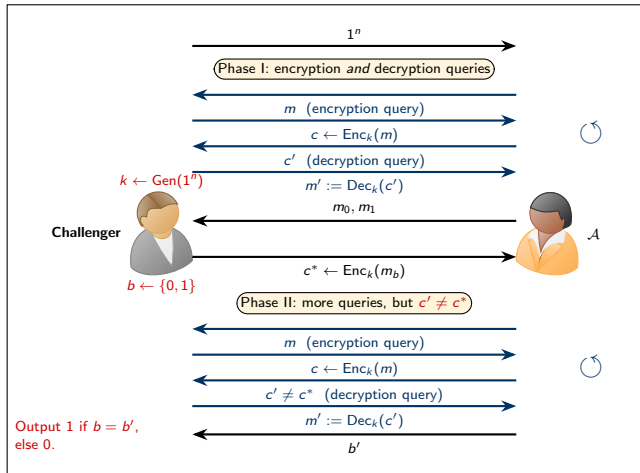
Definition 4 (CCA-Security)

$\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$ is **CCA-secure** if for all PPT $\mathcal{A}$:

$$\Pr[\text{PrivK}_{\mathcal{A}, \Pi}^{\text{CCA}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n).$$

$\text{PrivK}_{\mathcal{A}, \Pi}^{\text{CCA}}$: Challenger vs. Adversary

$\text{PrivK}_{\mathcal{A}, \Pi}^{\text{CCA}}(n)$



Authenticated Encryption: Intuition

Definition 5 (Authenticated Encryption)

A private-key encryption scheme is an authenticated encryption scheme if it is CCA-secure and unforgeable.

Unforgeable

It is hard to come up with legitimate-looking ciphertexts of **new** messages.

So decryption queries don't help

Every ciphertext $\mathcal{A}$ makes up itself decrypts to $\perp$ or to a message it already knows — the decryption oracle tells it nothing new.

Intuitively: Do the Two Notions Coincide?

Can a scheme be unforgeable but *not* CCA-secure?

Perhaps: if one can modify a given ciphertext into a **new** ciphertext of the **same** message. That is no forgery (the message is not new), but one decryption query on the modified challenge reveals m_b .

Can a scheme be CCA-secure but *not* unforgeable?

Perhaps: if one can come up with a fresh ciphertext of a **new** (but useless) message. That breaks unforgeability without helping to learn anything about m_b .

So we ask for **both** properties.

Authenticated Encryption Construction

Generic composition

Let (Enc, Dec) be CPA-secure and $(\text{Mac}, \text{Vrfy})$ be eu-cma-secure, with **independent** keys k_E and k_M . Three natural ways to combine them:

- ❶ **Encrypt and Authenticate:** $c \leftarrow \text{Enc}_{k_E}(m), \quad t \leftarrow \text{Mac}_{k_M}(m).$
- ❷ **Authenticate then Encrypt:** $t \leftarrow \text{Mac}_{k_M}(m), \quad c \leftarrow \text{Enc}_{k_E}(m \parallel t).$
- ❸ **Encrypt then Authenticate:** $c \leftarrow \text{Enc}_{k_E}(m), \quad t \leftarrow \text{Mac}_{k_M}(c).$

Encrypt and Authenticate

Construction

$$c \leftarrow \text{Enc}_{k_E}(m), \quad t \leftarrow \text{Mac}_{k_M}(m), \quad \text{output } \langle c, t \rangle.$$

The recipient decrypts c to get m , and accepts only if t is a valid tag on the message m .

Insecure

A Mac does not offer **secrecy**: the tag is computed on m itself and could leak the entire message. So this may not even be **CPA-secure**.

For example, with a deterministic Mac (such as $F_{k_M}(m)$), equal messages get equal tags: $\mathcal{A}$ queries m_0 and checks whether the challenge carries the same tag.

Authenticate then Encrypt

Construction

$$t \leftarrow \text{Mac}_{k_M}(m), \quad c \leftarrow \text{Enc}_{k_E}(m \parallel t), \quad \text{output } c.$$

The recipient decrypts c to get $m \parallel t$, and accepts only if t is a valid tag on the message m .

- **Is it CPA-secure?** Yes — it is Enc_{k_E} applied to $m \parallel t$.
- **Is it unforgeable?** Yes — a ciphertext of a new m must contain a valid tag on m .

But it is not CCA-secure in general

Enc is only CPA-secure. Given c^* , the attacker may be able to get a $c' \neq c^*$ that encrypts the **same** $m_b \parallel t$. Then c' passes verification, and one decryption query reveals m_b .

Encrypt then Authenticate

Construction

$$c \leftarrow \text{Enc}_{k_E}(m), \quad t \leftarrow \text{Mac}_{k_M}(c), \quad \text{output } \langle c, t \rangle.$$

The recipient accepts only if t is a valid tag on the **ciphertext** c , and in this case decrypts c to get m .

- **Is it unforgeable? Is it CCA-secure? Yes** — it is an authenticated encryption scheme if Mac is **strongly** unforgeable (proof below).
- **Why strongly?** If $\mathcal{A}$ could make a new tag $t' \neq t$ for the challenge $\langle c, t \rangle$, then $\langle c, t' \rangle$ is an allowed decryption query, and it decrypts to m_b .

Takeaway

Also, the **first CCA-secure encryption scheme** we have seen!

Can We Use the Same Key?

Set $k = k_E = k_M$

Encrypt then authenticate with a single key looks like
 $c \leftarrow \text{Enc}_k(m), \quad t \leftarrow \text{Mac}_k(c)$. Is it secure?

No!

Let F be a strong PRP. Take $\text{Enc}_k(m) := F_k(m \parallel r)$, where $m \in \{0, 1\}^{n/2}$ and $r \leftarrow \{0, 1\}^{n/2}$, and $\text{Mac}_k(c) := F_k^{-1}(c)$. Then

$$(\text{Enc}_k(m), \text{Mac}_k(\text{Enc}_k(m))) = (F_k(m \parallel r), F_k^{-1}(F_k(m \parallel r))) = (F_k(m \parallel r), m \parallel r).$$

The tag reveals the entire message.

Each part is secure on its own (F_k^{-1} is also pseudorandom when F is a strong PRP); the failure comes only from sharing the key. Use **independent** keys!

Encrypt then Authenticate: The Scheme

Let $\Pi_E = (\text{Gen}_E, \text{Enc}, \text{Dec})$ be an encryption scheme and $\Pi_M = (\text{Gen}_M, \text{Mac}, \text{Vrfy})$ a MAC.

Scheme $\Pi' = (\text{Gen}', \text{Enc}', \text{Dec}')$

- $\text{Gen}'(1^n)$: sample $k_E \leftarrow \text{Gen}_E(1^n)$ and $k_M \leftarrow \text{Gen}_M(1^n)$ independently.
- $\text{Enc}'_{k_E, k_M}(m)$: $c \leftarrow \text{Enc}_{k_E}(m)$, $t \leftarrow \text{Mac}_{k_M}(c)$; output $\langle c, t \rangle$.
- $\text{Dec}'_{k_E, k_M}(\langle c, t \rangle)$: if $\text{Vrfy}_{k_M}(c, t) = 1$, output $\text{Dec}_{k_E}(c)$; otherwise output $\perp$.

Theorem 6

If Π_E is CPA-secure and Π_M is strongly unforgeable, then Π' is an authenticated encryption scheme:

- (1) Π' is **unforgeable**, and
- (2) Π' is **CCA-secure**.

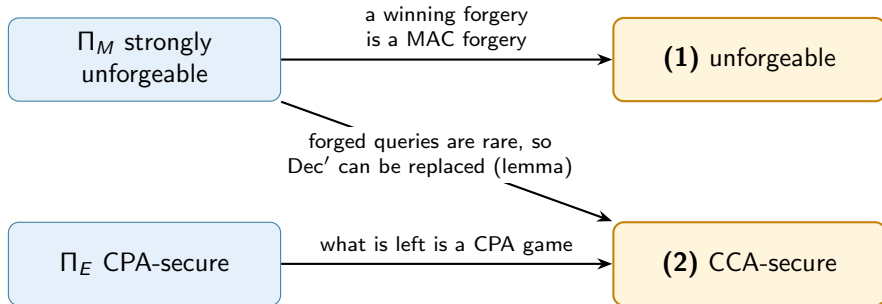
Three Kinds of Pairs

Any decryption query — or forgery — is a pair $\langle c, t \rangle$. There are only three kinds ($new = \mathcal{A}$ did not receive it from Enc' ; the challenge counts as $Enc'(m_b)$):

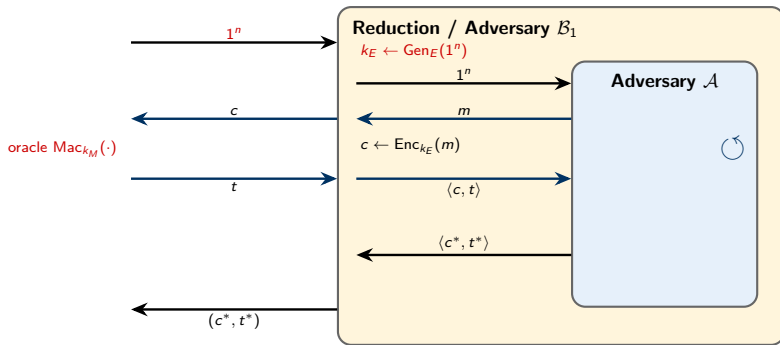
$\mathcal{A}$ submits $\langle c, t \rangle$ that is ...	Dec'_{k_E, k_M}	
old : Enc' returned it, on m	m	
invalid : new, $Vrfy_{k_M}(c, t) = 0$	$\perp$	
forged : new, $Vrfy_{k_M}(c, t) = 1$	$Dec_{k_E}(c)$	a MAC forgery!

A forged pair is a new pair (c, t) with a valid tag — exactly a win in $MacForge_{\Pi_M}^{str}$.

Proof Roadmap



(1) Unforgeable: Proof by Reduction



Given / To prove

Given: $\Pr[\text{EncForge}_{\mathcal{A}, \Pi'}(n) = 1] \geq \epsilon(n)$ for non-negligible ϵ .

To prove: $\Pr[\text{MacForge}_{\mathcal{B}_1, \Pi_M}^{\text{str}}(n) = 1] \geq \epsilon(n)$.

(1) Unforgeable: Putting It Together

$\mathcal{B}_1$ answers exactly as Enc' . Suppose $\mathcal{A}$ wins: $\text{Dec}'(\langle c^*, t^* \rangle) \notin \{\perp\} \cup Q$. Which kind of pair is it?

old
decrypts to $m \in Q$

invalid
decrypts to $\perp$

forged
the only option

a strong MAC forgery for $\mathcal{B}_1$

$$\Pr [\text{MacForge}_{\mathcal{B}_1, \Pi_M}^{\text{str}}(n) = 1] \geq \Pr [\text{EncForge}_{\mathcal{A}, \Pi'}(n) = 1] \geq \epsilon(n),$$

contradicting strong unforgeability of Π_M .

□

(2) A Decryption Oracle Without Keys

In the CCA game, $\mathcal{A}$'s decryption queries are pairs $\langle c, t \rangle$ of the same three kinds:

$\mathcal{A}$ submits $\langle c, t \rangle$ that is ...	real Dec'_{k_E, k_M}	FakeDec	
old : Enc' returned it, on m	m	m	
invalid : new, $\text{Vrfy}_{k_M}(c, t) = 0$	$\perp$	$\perp$	
forged : new, $\text{Vrfy}_{k_M}(c, t) = 1$	$\text{Dec}_{k_E}(c)$	$\perp$	a MAC forgery!

FakeDec: a lookup, **no key**

m if Enc' returned $\langle c, t \rangle$ on m (look it up in a list); else $\perp$. Differs from Dec' **only on forged pairs**.

So we may swap Dec' for FakeDec — unless $\mathcal{A}$ makes a forged query. First: that is rare.

(2) Lemma: Forged Queries Are Rare

Lemma

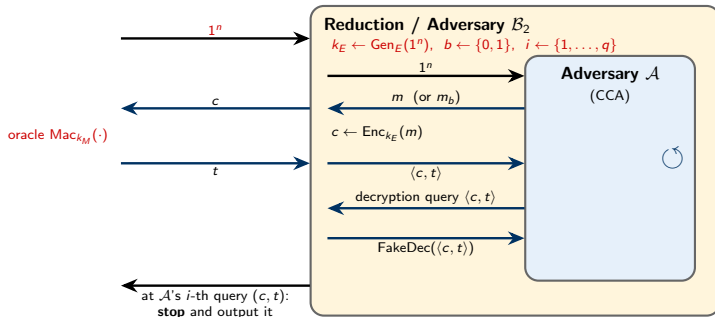
Let $\mathcal{A}$ play the real CCA game $\text{PrivK}_{\mathcal{A}, \Pi'}^{\text{CCA}}(n)$ with at most $q(n)$ decryption queries. If Π_M is strongly unforgeable:

$$\Pr [\mathcal{A} \text{ makes a forged decryption query}] \leq q(n) \cdot \text{negl}(n).$$

Why *strongly* unforgeable?

$\mathcal{A}$ may query $\langle c^*, t' \rangle$: the challenge's c^* with a new tag. As a MAC forgery, that is a new tag on an *old* message.

(2) Lemma: Proof by Reduction

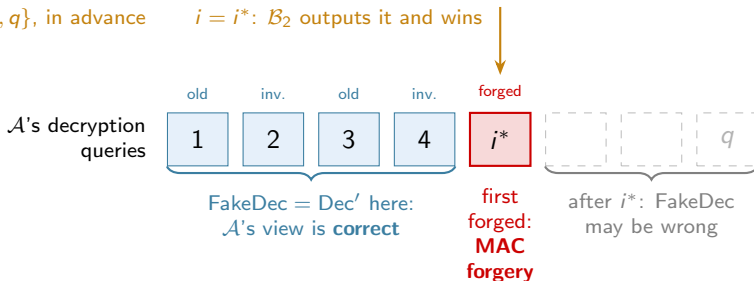


Given / To prove

Given: $\Pr[\mathcal{A} \text{ makes a forged query in the real CCA game}] \geq \epsilon(n)$ for non-negligible ϵ .

To prove: $\Pr[\text{MacForge}_{\mathcal{B}_2, \Pi_M}^{\text{str}}(n) = 1] \geq \epsilon(n)/q(n)$.

(2) Lemma: Putting It Together



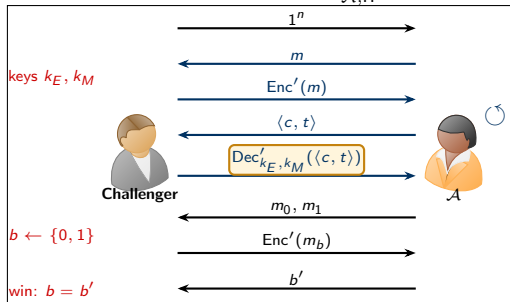
$$\Pr [\text{MacForge}_{\mathcal{B}_2, \Pi_M}^{\text{str}}(n) = 1] \geq \underbrace{\Pr[\text{a forged query occurs}]}_{\geq \epsilon(n)} \cdot \underbrace{\Pr[i = i^*]}_{= 1/q(n)} \geq \frac{\epsilon(n)}{q(n)}.$$

Non-negligible, contradicting strong unforgeability of Π_M .

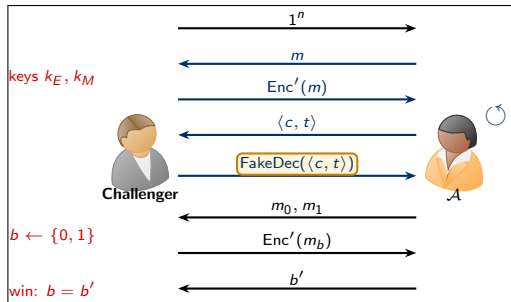
□

(2) Two Hybrids

H_0 : the real game $\text{PrivK}_{\mathcal{A}, \Pi'}^{\text{CCA}}(n)$



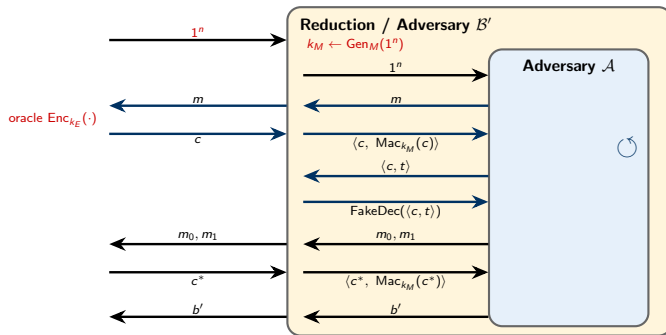
H_1 : decrypt with FakeDec



- Only the **boxed** answer differs — and by the table, only on a **forged** query. With the same keys and coins, $\mathcal{A}$ sees the same answers in both until its first forged query.

$$\begin{aligned} \Pr[\mathcal{A} \text{ wins in } H_0] &\leq \Pr[\mathcal{A} \text{ wins in } H_1] + \Pr[\mathcal{A} \text{ makes a forged query in } H_0] \\ &\leq \Pr[\mathcal{A} \text{ wins in } H_1] + q(n) \cdot \text{negl}(n) \quad (\text{lemma}). \end{aligned}$$

(2) Hybrid H_1 Is Just a CPA Game



Claim

$\mathcal{B}'$ plays H_1 exactly (it tags with its own k_M ; FakeDec needs no key), with $c^* = \text{Enc}_{k_E}(m_b)$:
 $\Pr[\mathcal{A} \text{ wins in } H_1] = \Pr[\text{PrivK}_{\mathcal{B}', \Pi_E}^{\text{CPA}}(n) = 1] \leq \frac{1}{2} + \text{negl}(n).$

(2) Putting It Together

Success probability of $\mathcal{A}$

$$\begin{aligned}\Pr [\text{PrivK}_{\mathcal{A}, \Pi'}^{\text{CCA}}(n) = 1] &\leq \Pr[\mathcal{A} \text{ wins in } H_1] + \Pr[\text{forged query in } H_0] && \text{(hybrids)} \\ &\leq \left(\frac{1}{2} + \text{negl}(n)\right) + q(n) \cdot \text{negl}(n) && \text{(CPA; lemma)} \\ &= \frac{1}{2} + \text{negl}'(n),\end{aligned}$$

since q is polynomial. So Π' is CCA-secure. □

Remark (running time)

$\mathcal{B}_1$, $\mathcal{B}_2$ and $\mathcal{B}'$ run $\mathcal{A}$ once, plus one encryption, one tag, or one lookup per query: PPT.

Takeaway

The MAC makes the decryption oracle useless; CPA-security of Π_E does the rest.

Authenticated encryption is not the whole story

Even with authenticated encryption of every message, a session of many messages faces further attacks:

- **Re-ordering attack** — the adversary delivers messages out of order.
- **Replay attack** — the adversary re-sends an old (valid) message.
- **Reflection attack** — the adversary sends a message back to its own sender.

Fix

Include a **counter** and a **direction bit** in every message that is encrypted.

Summary

- **Unforgeable encryption:** via the game $\text{EncForge}_{\mathcal{A}, \Pi}(n)$, no PPT $\mathcal{A}$ can produce a ciphertext of a new valid message. The CPA-secure PRF-based scheme is not unforgeable.
- **Authenticated encryption = CCA-secure + unforgeable:** unforgeability makes decryption queries useless.
- Generic composition with independent keys:
 - Encrypt and Authenticate: the tag can leak m — not even CPA-secure in general.
 - Authenticate then Encrypt: CPA-secure and unforgeable, but not CCA-secure in general.
 - **Encrypt then Authenticate:** authenticated encryption if Mac is strongly unforgeable — our first CCA-secure scheme. *Proved:* a new ciphertext with a valid tag is a MAC forgery; so forgeries are rare, and the decryption oracle can be replaced by a key-free lookup, leaving a CPA game.
- Using the same key for both parts can break security completely.
- Sessions need **counters** and a **direction bit** to stop re-ordering, replay, and reflection attacks.